

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 47

Apply S3 Block Public Access at Bucket and Account Levels

Amazon S3 | Block Public Access | ACLs | Bucket Policies | Access Analyzer

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.0
RELEASE DATE	August 5, 2026
STATUS	Complete - Analyzer Validation Pending

Executive Summary

Applied Amazon S3 **Block Public Access (BPA)** controls at both the bucket and account levels. In **TestAccount1**, the bucket-policy test bucket was configured to ignore public access granted through **any ACL** and to block public and cross-account access granted through **any public bucket or access point policy**. The SLAW ACL bucket was configured with the two **new access only** controls, preventing new public ACLs and new public bucket or access point policies without changing existing public grants. The session then moved to the **SecurityAudit** account, where **Block all public access** was enabled account-wide.

KEY
DISTINCTION

The two TestAccount1 buckets intentionally use different BPA modes. The BP bucket blocks existing and future effective public access through ACLs and policies, while the SLAW bucket only prevents new public configurations and may remain public through pre-existing permissions.

Business Problem

S3 public access can be introduced through ACLs, bucket policies, and access point policies. Applying an immediate account-wide lockout can break legitimate public workloads, while only blocking future changes leaves existing exposure in place. BPA provides granular controls that support both immediate remediation and staged migration.

Objectives

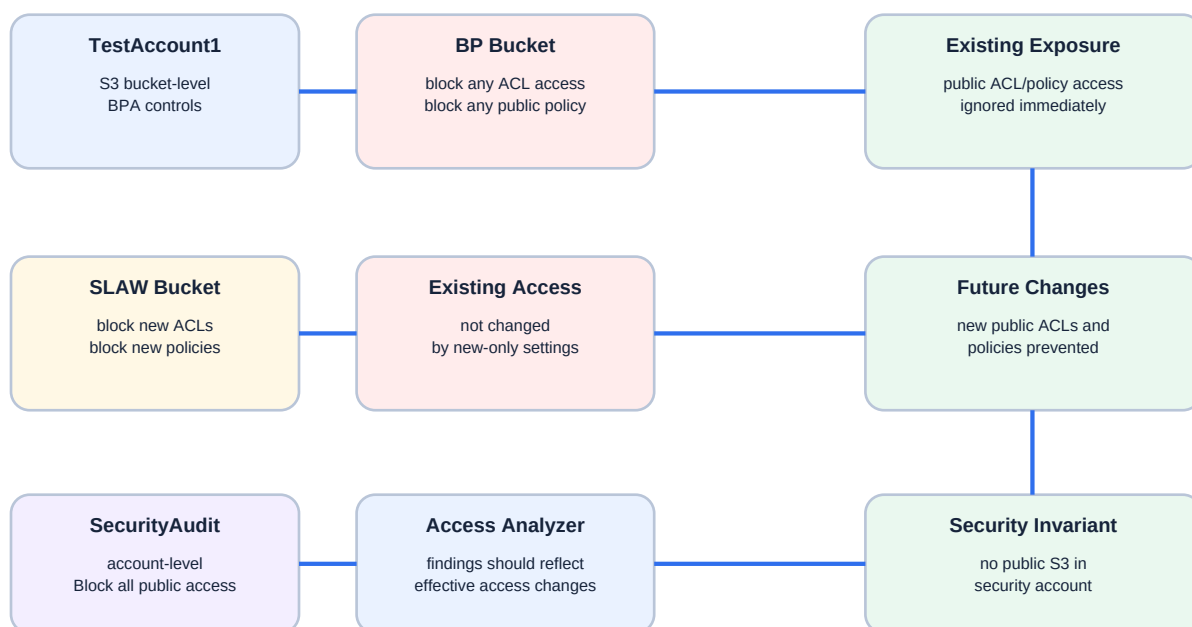
- Sign into TestAccount1 with AdministratorAccess.
- Open the BP bucket Block Public Access settings.
- Ignore public access granted through any ACL.
- Block public and cross-account access granted through any public bucket or access point policy.
- Open the SLAW bucket Block Public Access settings.
- Prevent new public ACLs without changing existing ACL permissions.
- Prevent new public bucket and access point policies without changing existing policies.
- Sign into the SecurityAudit account.
- Enable Block all public access for the SecurityAudit account.
- Prepare for follow-up review of IAM Access Analyzer findings.

Environment

Cloud Provider	Amazon Web Services
Primary Service	Amazon S3 Block Public Access

Account 1	TestAccount1
BP Bucket Mode	Block any public ACL access and any public/cross-account bucket or access point policy access
SLAW Bucket Mode	Block new public ACLs and new public bucket or access point policies only
Account 2	SecurityAudit
SecurityAudit Mode	Block all public access at the account level
Related Detection	IAM Access Analyzer external-access findings
Status	Complete - Access Analyzer effect validation pending

Architecture



BPA can immediately ignore existing public grants or only prevent future public configuration.

Figure 1 - Bucket-level staged BPA controls and account-level SecurityAudit lockdown.

Implementation Summary

1. Logged into TestAccount1.
2. Opened the BP bucket and navigated to Permissions > Block public access.
3. Enabled the setting that ignores public access granted through any access control list.

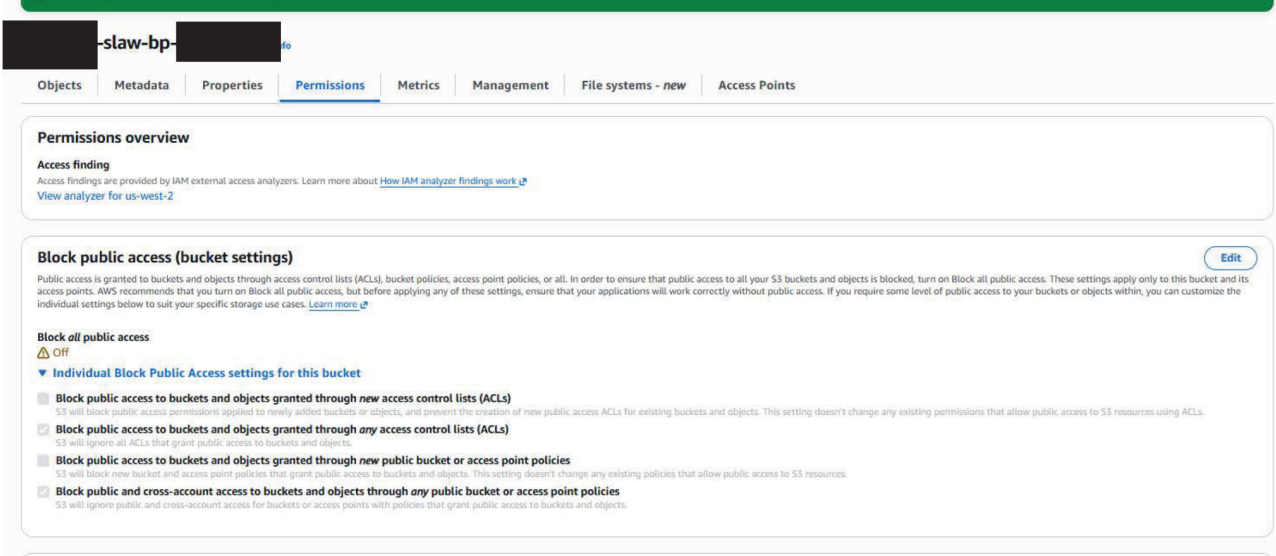
4. Enabled the setting that blocks public and cross-account access through any public bucket or access point policy.
5. Saved and confirmed the BP bucket changes.
6. Opened the SLAW bucket and navigated to its Block Public Access settings.
7. Enabled the setting that blocks public access granted through new ACLs.
8. Enabled the setting that blocks public access granted through new public bucket or access point policies.
9. Saved and confirmed the SLAW bucket changes.
10. Logged out of TestAccount1 and signed into SecurityAudit.
11. Opened S3 account-level Block Public Access settings.
12. Enabled Block all public access for the SecurityAudit account.

BPA Setting Comparison

Block new public ACLs	Not selected separately	Enabled	Prevents new public ACL configuration but does not remove existing ACL grants.
Block any public ACLs	Enabled	Not enabled	Ignores existing and future ACL-based public access.
Block new public policies	Not selected separately	Enabled	Prevents new public bucket/access point policies but does not change existing policies.
Block any public/cross-account policies	Enabled	Not enabled	Ignores existing and future public or cross-account policy access.
Block all public access	Effective through the two broad 'any' settings	Off	SLAW remains a staged-remediation bucket rather than a complete lockout.
Account-level BPA	Not changed	Not changed	SecurityAudit was fully locked down at the account level.

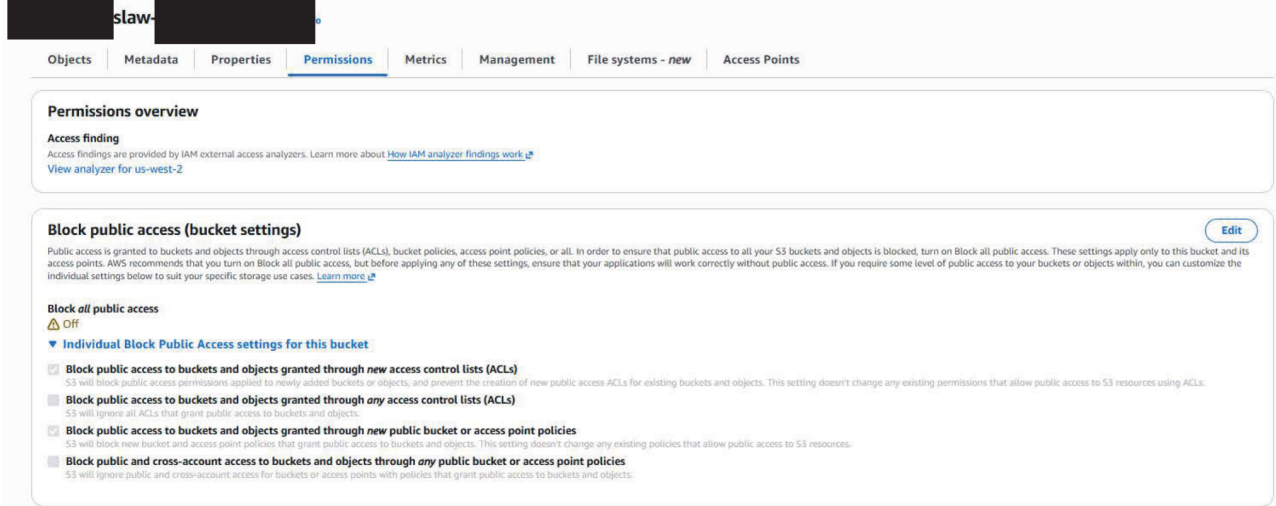
Evidence

Figure 2 - BP Bucket Blocks Existing ACL and Policy-Based Public Access



The BP bucket evidence shows Block all public access displayed as Off because the individual controls are customized. The selected controls are 'Block public access ... through any access control lists (ACLs)' and 'Block public and cross-account access ... through any public bucket or access point policies.'

Figure 3 - SLAW Bucket Prevents New Public ACLs and Policies



The SLAW bucket evidence shows the two new-only controls selected: blocking public access through new ACLs and blocking public access through new public bucket or access point policies. The controls that ignore any existing ACLs or policies remain unselected.

EVIDENCE STATUS

SecurityAudit account-level Block all public access is documented from the completed-lab update. A separate screenshot of the account-level SecurityAudit setting was not attached.

Security Analysis

BPA evaluates the effective public-access mechanism and can override access granted through ACLs, bucket policies, and access point policies.

The BP bucket uses the broad 'any' settings, which immediately ignore existing public grants and also protect against future grants through those mechanisms.

The SLAW bucket uses new-only settings. Existing public access is not removed, but new public ACLs and policies are prevented. This is useful for staged remediation.

Account-level Block all public access in SecurityAudit establishes a strong invariant that the centralized security account should not host public S3 resources.

BPA is not organization-wide by itself. Account-level settings apply per account; organization-wide protection requires supporting controls such as SCPs, RCPs, and account-factory defaults.

IAM Access Analyzer should be used after BPA changes to confirm which resources remain effectively public or externally shared.

Lessons Learned

S3 BPA can be configured per bucket or per account.

Broad 'any' settings can immediately neutralize existing public ACL and policy access.

New-only settings stop additional exposure without remediating existing exposure.

The customized bucket view can show Block all public access as Off even when selected individual controls provide equivalent protection for the relevant mechanisms.

Security accounts should normally use account-level Block all public access.

Access Analyzer provides verification of effective exposure after control changes.

Production Improvements

- Use Access Analyzer to inventory existing public buckets before broad BPA rollout.
- Enable account-level Block all public access in accounts that should never host public resources.
- Use new-only controls as a temporary containment step while existing public resources are reviewed.
- Back BPA with an SCP that prevents unauthorized users from disabling it.
- Enable BPA automatically in the account-vending or account-factory process.
- Maintain a controlled exception process for approved public production buckets.
- Monitor PutAccountPublicAccessBlock, PutPublicAccessBlock, and DeletePublicAccessBlock events.
- Recheck Access Analyzer findings after every BPA remediation change.

Skills Demonstrated

Block Public Access	Bucket-level controls	Immediate remediation
Account-level controls	Staged remediation	ACL and policy analysis

Security invariants	Access Analyzer validation	Exception planning

Resume Bullet

RESUME	Applied granular Amazon S3 Block Public Access controls by immediately blocking existing ACL and bucket-policy exposure on one bucket, preventing only new public grants on a second bucket, and enabling account-wide public-access blocking in the SecurityAudit account.
--------	---

STAR Interview Story

Situation: Access Analyzer identified externally accessible resources after the portfolio intentionally created public S3 buckets through ACLs and bucket policies.

Task: Apply protective controls without treating every bucket the same or immediately disrupting all existing access.

Action: I configured the BP bucket to ignore any ACL-based public access and any public or cross-account policy access, configured the SLAW bucket to block only new ACLs and policies, and enabled account-level Block all public access in SecurityAudit.

Result: The lab demonstrated immediate remediation, staged containment, and account-level security invariants while preserving a remaining exposure target for Access Analyzer validation.

Version History

v1.0.0	August 5, 2026	Initial documentation. Applied broad BPA controls to the BP bucket, new-only BPA controls to the SLAW bucket, enabled account-level Block all public access in SecurityAudit, embedded two evidence screenshots, and documented the difference between immediate and staged remediation.

References

- Cloud Security Lab a Week - Block Public Access Without Pissing People Off.
- User-provided BP bucket Block Public Access evidence.
- User-provided SLAW bucket Block Public Access evidence.
- Project 43 - S3 ACL Public Bucket Exposure.
- Project 44 - S3 Misconfigured Bucket Policy Exposure.
- Project 46 - IAM Access Analyzer Delegated External Access.